AES Raptor Ultra CNC İşleme
Secure Remote Access

Kavramsal Çerçeve: İki Katmanlı Savunma (Defense-in-Depth)

(AB) 2023/1230 Yeni Makine Tüzüğü Ek III (Madde 1.1.9 *Yozlaşmaya Karşı Koruma* ve Madde 1.2.1 *Kontrol Sistemlerinin Güvenliği*), Siber Dayanıklılık Yasası (CRA — AB 2024/2847) ve IEC 62443 standartları kapsamında, AES Raptor Ultra gibi ağa bağlı bir CNC işleme merkezinde güvenli mimari (*Secure Architecture*) birbirini tamamlayan **iki zorunlu katmana** dayanır:

1. **Katman 1 — Erişim Güvenliği (Girişi Zorlaştır):** Dış servis ağından veya fabrika IT ağından makinenin kontrol katmanına (OSAI/Syntec CNC ve AES PLC) yetkisiz erişimi ara nokta (*Jump Server*), şifreli tünel (*VPN*), çok faktörlü kimlik doğrulama (*MFA*), kişisel hesaplar, tam oturum kaydı (*Tracing Log*) ve varsayılan kapalı (*Default Deny*) ilkeleriyle zorlaştırmak.

2. **Katman 2 — Emniyet Bağımsızlığı (Girse Bile İnsan Korunur):** Saldırgan tüm siber erişim engellerini aşarak CNC kontrol bilgisayarını veya standart PLC'yi ele geçirse dahi, insan hayatını koruyan emniyet fonksiyonlarının (100 m/dk portal durdurma, ışık perdeleri, 24.000 RPM iş mili kilitleme ve 5 Bar vakum/basınç kilidi) siber müdahaleden etkilenmeden bağımsız olarak çalışmaya devam etmesini sağlamak.

Görev A: Mevcut Durumdan Hedef Mimariye Geçiş (Mevcut → Hedef)

1. MEVCUT MİMARİ (Zafiyet Barındıran Geleneksel / Düz Ağ Kurulumu)

Geleneksel saha kurulumlarında uzaktan bakım ve dosya paylaşımı hız odaklı kurgulandığından siber-fiziksel izolasyon bulunmamaktadır:

- **Doğrudan Bağlantı ve Açık Portlar:** Servis mühendisi dış internetten (TeamViewer, AnyDesk veya doğrudan açık RDP/VNC portları üzerinden) Windows/PC tabanlı *NC Hops / Alphacam* arayüzüne ve *OSAI / Syntec* CNC kontrolcüsüne doğrudan bağlanır.

- **Paylaşılan Parola ve Sürekli Açık Kanal:** Tüm servis ekibi ortak bir "service/admin" parolası kullanır; uzak erişim servisi 7/24 açık bekler ve yapılan bellenim/parametre değişikliklerinin 5 yıllık yasal izleme kaydı (*Tracing Log*) tutulmaz.

- **Düz Ağ (Flat Network) ve Emniyet Bağımlılığı:** Fabrika IT ağı, CNC kontrolcü, standart AES PLC ve emniyet ekipmanları aynı düz Ethernet ağı üzerinde birleşiktir. Emniyet limitleri (ör. 100 m/dk hız sınırı veya ışık perdesi *override/bypass* bitleri) yazılımsal olarak standart kontrolcü üzerinden değiştirilebilir durumdadır.

MEVCUT (ZAFİYETLİ) UZAK ERİŞİM ŞEMASI

[Dış Servis / İnternet] −−−−−−−−−−−−−−−−−−−−Doğrudan Bağlantı + Tek/Paylaşılan Parola→

[Fabrika Düz Ağı (IT + OT Sürekli Açık, Kayıtsız **Birleşik)]**

↓ *(Ağ İzolasyonu ve Firewall Yok)*

OSAI / Syntec CNC + NC Hops PC + 21" HMI + AES PLC (Aynı Düz Ağda)

Risk: Uzaktan giren saldırgan eksen hız limitlerini (100 m/dk), vakum valflerini ve yazılımsal emniyet bitlerini doğrudan değiştirebilir!

(Çift Yönlü Yazılımsal Bağımlılık — Emniyet Bağımsızlığı Yok!)

[Işık Perdesi / Lazer Tarayıcı / İş Mili Kilidi / Panasonic Servo Sürücüler]

2. HEDEF MİMARİ (Beş Temel İlke + Emniyet İzolasyonu ile Yeniden Tasarım)

IEC 62443, (AB) 2023/1230 Makine Tüzüğü ve CRA gerekliliklerine göre uzak erişim mimarisi **beş temel erişim güvenliği ilkesi** ve **emniyet bağımsızlığı** ile yeniden tasarlanmıştır:

1. **İlke 1 — Ara Nokta (Endüstriyel DMZ Jump Server / Bastion Host):** Dış ağdan CNC veya PLC'ye doğrudan IP bağlantısı kesinlikle yasaklanmıştır. Bağlantı önce Endüstriyel DMZ (Bölge 2) içindeki sıkılaştırılmış *Jump Server* üzerinde sonlandırılır (*protocol break*); yüklenen kesim dosyaları ve yamalar burada zararlı yazılım ve kriptografik imza (*Secure Boot*) kontrolünden geçirilir.

2. **İlke 2 — Güçlü Kimlik ve Kişisel Hesap (VPN + MFA + Bireysel RBAC):** İletişim yalnızca sertifika tabanlı **IPsec / TLS 1.3 VPN** tüneli içinden yapılır. Paylaşılan hesaplar kapatılarak her servis mühendisine **kişisel hesap** ve **Çok Faktörlü Kimlik Doğrulama (MFA)** tanımlanır; Rol Tabanlı Erişim Kontrolü (RBAC) ile yetkiler sınırlandırılır.

3. **İlke 3 — Varsayılan Kapalı ve Operatör Onaylı Zamanlama (Default Deny):** Uzak bakım kanalı (Conduit 3) normal üretimde fiziksel ve mantıksal olarak kapalıdır. Yalnızca arıza/bakım anında sahadaki operatörün 21 inç HMI konsolu üzerinden verdiği onay (*Request-toConnect*) veya fiziksel bakım anahtarı ile geçici olarak açılır ve süre sonunda otomatik kapanır.

4. **İlke 4 — Tam Oturum ve Yazılım İzleme Kaydı (Audit & 5 Yıllık Tracing Log):** Uzak oturum boyunca yapılan tüm işlemler, ekran videoları, komutlar ve yüklenen yazılım versiyonları (AB) 2023/1230 Ek III Madde 1.1.9 ve 1.2.1 gereği değiştirilemez (*write-once*) zaman damgalı kayıt defterine işlenir ve **5 yıl boyunca** saklanır.

5. **İlke 5 — Tek Yönlü Emniyet Ayrımı (OT Safety Zone İzolasyonu):** OT Hücre Kontrol Bölgesi (OSAI/Syntec CNC ve Normal AES PLC) ile Fonksiyonel Emniyet Bölgesi (**Safety PLC / Emniyet Röleleri**) birbirinden ayrılmıştır. Emniyet bölgesinden kontrol bölgesine yalnızca **salt okunur (read-only)** durum bilgisi akar; ağ üzerinden emniyet bölgesine yazma (*write*) veya köprüleme (*bypass*) yapılamaz.

HEDEF (GÜVENLİ) UZAK ERİŞİM VE EMNİYET BAĞIMSIZLIĞI ŞEMASI

[Yetkili Servis Mühendisi]

↓ **(1) VPN Tüneli (TLS 1.3/IPsec)** + **(2) MFA & Kişisel Hesap**

KATMAN 1: ERİŞİM GÜVENLİĞİ — BÖLGE 2 (Endüstriyel DMZ)

(3) Ara Nokta (Jump Server) • (4) Tam Oturum Kaydı (5 Yıllık Tracing Log) • Secure Boot İmza Kontrolü

↓ **(5) Varsayılan Kapalı (Default Deny)** — *Yalnızca 21" HMI Operatör Onayıyla Geçici Açılır (Conduit 3)*

BÖLGE 4: OT HÜCRE KONTROL (OSAI / Syntec CNC + Normal AES PLC + HMI)

Operasyonel parametreler, G-kodu işleme, ATC magazin, Vacuboost valfleri ve hız komutları

↑ **Conduit 5: Tek Yönlü / Salt Okunur Teşhis** *(Kontrol Sisteminden Safety Katmanına Ağdan Yazma*

KATMAN 2: EMNİYET BAĞIMSIZLIĞI — BÖLGE 5 (OT Safety Zone / EN ISO 13849-1 PL d / PL e)

Donanımsal Çift Kanallı Emniyet Devresi: Işık Perdesi / Lazer Tarayıcı / E-Stop / 0 RPM & 5 Bar Şalterleri −→ **Doğrudan Donanımsal STO / Güç Kesme** −→ **GÜVENLİ DURUŞ (SAFE STATE)**

YASAK!)

Görev B: Functional Safety (Fonksiyonel Emniyet) Köprüsü

1. Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenirmi? Neden?

Bu sorunun cevabı, makinenin kontrol mimarisinde **Katman 2 (Emniyet Bağımsızlığı)** ilkesinin uygulanıp uygulanmadığına göre iki farklı mühendislik sonucu doğurur:

- **Durum 1 — Eğer Emniyet Fonksiyonları Yazılımsal Olarak Kontrol Sistemine Bağımlıysa (Mevcut / Zafiyetli Mimari): EVET, DOĞRUDAN ETKİLENİR.**

  Neden: Eğer ışık perdeleri, lazer alan tarayıcı, 100 m/dk hız sınırları, HSK-F63 iş mili 0 RPM pens kilidi veya 5 Bar vakum/pnömatik basınç izleme sinyalleri standart **AES PLC** veya PC tabanlı **OSAI/Syntec** kontrolcü belleği üzerinden yazılımsal olarak yönetiliyorsa; tüm erişim önlemlerini (VPN, MFA, Jump Server) aşarak veya çalınmış bir mühendis kimliğiyle içeri sızan saldırgan kontrol sisteminde tam yetki (*write/override*) kazanır. Saldırgan PLC belleğindeki ışık perdesi *bypass* bitlerini aktif edebilir, G-kodu hız limitlerini ezebilir veya kontrolcüye Hizmet Reddi (*DoS / Buffer Overflow*) saldırısı yaparak işlemciyi kilitleyebilir. Kontrolcü kilitlendiğinde veya emniyet bitleri köreltildiğinde, operatör tehlike bölgesine girse dahi Panasonic servo sürücülere durma komutu gitmez ve 1000 kg'lık portal köprü operatöre çarparak ölümcül yaralanmaya yol açar.

- **Durum 2 — Eğer Emniyet Fonksiyonu Kontrol Sisteminden Fiziksel ve Mantıksal Olarak İzole Edilmişse (Hedef Mimari): HAYIR, ETKİLENMEZ (İNSAN KORUNUR).**
  Neden: Hedef mimaride emniyet fonksiyonları (SRP/CS), operasyonel CNC/PLC kontrol sisteminden tamamen ayrı bir donanımsal güvenlik yolunda (*Safety Path*) çalışır. Saldırgan tüm siber savunmaları aşıp OSAI/Syntec CNC bilgisayarını ve standart AES PLC'yi tamamen ele geçirse, hatta 21 inç HMI ekranını kilitleyip eksenlere maksimum hızda (100 m/dk) çarpışma komutu gönderse bile:

  1. Emniyet bölgesi (Bölge 5) ağ üzerinden hiçbir *yazma (write)*, *konfigürasyon değiştirme* veya *köprüleme (bypass)* komutu kabul etmediği için saldırgan emniyet mantığını değiştiremez.
  2. Operatör ön yükleme alanındaki dikey ışık perdesini veya lazer tarayıcı alanını ($S_{\text{min}} = 500–1543$ mm) kestiği anda, ya da pnömatik basınç 5 Bar altına düştüğünde, bağımsız emniyet devresi CNC işlemcisine sormaksızın Panasonic servo sürücülerin **STO (Safe Torque Off)** girişlerini ve HSD VFD invertör enerjisini donanımsal olarak keser.
  3. Böylece makine en geç $t_2 = 250$ ms içinde güvenli duruşa (*Safe State*) geçer; siber saldırı üretimi durdurabilir ancak **operatöre fiziksel zarar veremez**.

2. Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).

*Not: Laboratuvar föyündeki tarafsızlık ilkesi uyarınca aşağıda belirli bir marka, ürün veya devre şeması (çözüm) dayatılmamış; tasarım ekibinin uyması gereken doğrulanabilir mühendislik ve regülasyon **GEREKSİNİMLERİ (Requirements)** tanımlanmıştır.*

Ana Mimari Emniyet Bağımsızlığı Gereksinimi (Üst Seviye Gereksinim):

[REQ-SAFE-MAIN] Makinenin insan hayatını ve fiziksel bütünlüğünü koruyan tüm emniyet fonksiyonları (SRP/CS); standart üretim kontrol sisteminin (CNC ünitesi, standart PLC, HMI ve fabrika/uzak erişim ağlarının) arızalanması, kilitlenmesi, gecikmesi veya kötü niyetli siber müdahale sonucu tamamen ele geçirilmesi durumlarından etkilenmeyecek şekilde **mantıksal ve fiziksel olarak bağımsız** olmalı ve her

koşulda tanımlı tepki süresi içinde makineyi **Güvenli Duruma (Safe State)** geçirebilmelidir *((AB) 2023/1230 Ek III Madde 1.1.9 & 1.2.1; EN ISO 13849-1)*.

Alt Fonksiyonel ve Siber-Fiziksel Bağımsızlık Gereksinimleri:

Gereksinim Kodu	Gereksinim Tanımı (Ne Sağlanmalı? — Çözüm Değil, Kural)	İlgili Tehlike ve Standart
REQ-DEP-01 (Yozlaşmazlık ve Tek Yönlülük)	Operasyonelkontrolağı(CNC/PLC/HMI)veyauzakservis bağlantıları üzerinden emniyet fonksiyonlarının mantığına, eşik değerlerine ve çalışma moduna hiçbir koşulda **yazma, değiştirme veya devre dışı bırakma (bypass/override)** erişimi bulunmamalıdır; emniyet katmanından kontrol katmanına veri akışı yalnızca **tek yönlü (salt okunur teşhis)** olmalıdır.	(AB) 2023/1230 Ek III Madde 1.1.9 IEC 62443-3-3 (SR 5.1 Ağ Segmentasyonu)
REQ-DEP-02 (Doğrudan Enerji Kesme Önceliği)	Emniyet algılayıcılarından (optik bariyerler, alan tarayıcılar, acildurdurma)gelendurdurmatalebi, standartkontrol sisteminin yazılım döngüsüne veya ağ trafiğine uğramaksızın, tahrik elemanlarının (eksen sürücüleri ve iş mili) tork/güç üretimini **en yüksek öncelikle ve doğrudan** sonlandırmalıdır.	100 m/dk Portal Çarpma ve Ezilme Riski EN ISO 13849-1 (PL d/PL e)
REQ-DEP-03 (Deterministik Tepki Süresi)	Standart kontrol sisteminde veya ağ arayüzünde yüksek veri trafiği, Hizmet Reddi (DoS) saldırısı veya işlemci kilitlenmesi yaşansa dahi, emniyet fonksiyonunun toplam duruş tepki süresi ($T = t_1 + t_2 \leq 0.308$ sn) hiçbir gecikmeye uğramadan deterministik olarak korunmalıdır.	(AB) 2023/1230 Ek III Madde 1.2.1 EN ISO 13855 Güvenlik Mesafesi (S_{min})
REQ-DEP-04 (Sıfır Hız ve Tutma Bütünlüğü)	Yüksek hızda dönen kesici takımın bırakılması (unclamp) fonksiyonu, standart kontrol yazılımının komutlarından bağımsız olarak yalnızca dönüş hızının fiziksel olarak sıfır (RPM = 0) olduğunun doğrulanması şartına bağlanmalı; iş parçası tutma (vakum/basınç ≥ 5 Bar) kaybında isekesimilerlemesikontrolsistemindenbağımsızolarak güvenli duruşa geçirilmelidir.	24.000 RPM Takım ve Parça Fırlaması EN ISO 19085-3:2021 Madde 5.3.2
REQ-DEP-05 (Kablosuz İletişim Fail-Safe Kuralı)	Operatörün hareketli/kablosuz kontrol ünitelerini kullandığı senaryolarda, iletişim sinyalinin kesilmesi, bozulması veya dış parazite (RF/Jamming) maruz kalması durumunda emniyet fonksiyonu otomatik olarak tetiklenmeli ve makineyi güvenli duruma geçirmelidir.	İstemsiz Eksen Hareketi EN 60204-1:2018 & EN ISO 13849-1

Tablo 1: AES Raptor Ultra İçin Emniyet Bağımsızlığı Gereksinim Tablosu (EP 02 + EP 06)

Kaynakça

1. **AES Group Raptor Ultra Teknik Analiz Raporu**: CE Uygunluk Değerlendirmesi İçin Tersine Mühendislik Tabanlı Kör Analiz ve Laboratuvar Doğrulama Raporu (3. ve 4. Laboratuvar Uygulamaları: Fonksiyonel Emniyet ve Siber-Fiziksel Güvenlik Denetimi).

2. **Yeni Makine Tüzüğü**: Avrupa Birliği (AB) 2023/1230 Makine Tüzüğü, Ek III Madde 1.1.9 (Yozlaşmaya Karşı Koruma) ve Madde 1.2.1 (Kontrol Sistemlerinin Güvenliği, Güvenilirliği ve 5 Yıllık Yazılım İzleme Kaydı Zorunluluğu).

3. **Siber Dayanıklılık Yasası (CRA)**: Avrupa Birliği (AB) 2024/2847 Yönetmeliği, Ek I (Tasarımda ve Varsayılanda Güvenlik Gereklilikleri) ve Madde 14 (Zafiyet Bildirim Yükümlülükleri).

4. **Endüstriyel Siber Güvenlik Standartları**: IEC 62443-3-2 (Zones & Conduits Risk Değerlendirmesi) ve IEC 62443-3-3 (Sistem Güvenlik Gereklilikleri — SR 1 Kimlik Doğrulama, SR 5 Ağ Segmentasyonu).

5. **Makine ve Fonksiyonel Emniyet Standartları**: EN ISO 19085-3:2021 (NC/CNC delik ve freze makineleri güvenliği), EN ISO 13849-1 (Kontrol sistemlerinin güvenlikle ilgili kısımları — SRP/CS) ve EN ISO 13855 (Koruyucuların konumlandırılması).